

澄川制造私有化部署安全要求

SEC-SYN-2026-09 · 合成基准材料

1. 部署边界

- 系统部署在客户自有数据中心，不使用公有云托管数据库或 AWS S3。对象存储采用客户内网私有 MinIO 集群，通过 S3 兼容 API 接入。
- 生产、UAT、开发环境使用独立数据库、Bucket、密钥和服务账号；不得跨环境复用访问凭证。
- 互联网用户只可经双机 WAF 和 API 网关进入应用区；应用区不能直接访问互联网，外部模型调用必须经过审计代理并允许关闭。

2. 身份、网络与数据

- 管理后台接入企业 OIDC，管理员强制 MFA；服务账号使用最小权限并每 90 天轮换。
- 数据库与 MinIO 位于数据区，只允许应用区和备份区的明确端口访问；运维访问必须经过堡垒机。
- 传输使用 TLS 1.2 及以上。数据库、备份和 MinIO 服务端加密开启，密钥由客户 KMS 托管。
- MinIO Bucket 必须为私有；下载签名 URL 有效期 10 分钟。上传文件先进入 quarantine Bucket，恶意文件扫描通过后才能进入正式 Bucket。

可用性、备份与容量要求

正式方案必须保持数值一致

3. 可用性与恢复

- 生产应用部署 3 个实例并跨 3 台计算节点；PostgreSQL 采用 2 个数据库节点加 1 个仲裁节点；MinIO 使用 4 节点纠删码集群。
- 月度可用性目标为 99.9%。数据库目标 RPO 为 15 分钟、RTO 为 2 小时；对象存储目标 RPO 为 1 小时、RTO 为 4 小时。
- 数据库每周全量、每日增量并持续归档 WAL；MinIO 每日增量复制到备份区。备份保留 35 天，并每季度执行一次恢复演练。

4. 容量与性能

- 一期注册用户 400 人，峰值并发 80 人；每日新增文件 12,000 个，单文件最大 30 MB，日均原始新增量 180 GB。
- 原始文件在线保留 365 天，归档保留 5 年。容量估算按原始数据 $\times 1.35$ 派生与版本系数 $\times 1.5$ MinIO 冗余系数 $\times 1.2$ 余量计算。
- Web/API 正常排队 P95 不超过 5 秒；突发容量排队 P95 不超过 30 秒。单用户不得占用超过 25% 的 Worker 并发。

运营、安全与范围边界

实施计划和报价须显式列出责任方

5. 安全运营

- 安全日志在线保留 180 天、归档保留 3 年；认证失败、跨租户访问、恶意文件、密钥读取和删除操作均生成审计事件。
- 高危漏洞须在 72 小时内完成修复或隔离；中危漏洞在 30 天内处理。每季度复核服务账号、网络白名单和备份恢复证据。
- 删除任务必须覆盖数据库、正式 Bucket、quarantine Bucket、缓存和备份索引，并保留不可反向恢复的删除墓碑。

6. 外部成本与首期排除

- 资源表中的硬件、KMS、WAF、堡垒机、杀毒引擎、备份介质和专线属于客户采购或第三方成本，软件实施报价必须单独列示，不得默认为已包含。
- 首期不包含双数据中心双活、跨境数据传输、公共互联网 Bucket、AWS S3、自动购买硬件、自动执行生产扩容和替客户签署等保测评结论。